
Infrastructure as a Battlefield

Zero days, infraestructura crítica y defensa activa responsable

Socio Technical Impact Analysis of Nicole Perlroth's
This Is How They Tell Me the World Ends

Integrantes: Pablo Alvarado, Andrés Proaño, Roberto Villafuertes

Curso: CMP 5006 Seguridad Informática

Profesor: Alejandro Adrian Proaño Lozada

Roberto

- 1 Contexto del libro
- 2 Zero days
- 3 Mercado y ética
- 4 Militarización del código

Pablo

- 1 IT contra OT
- 2 PLCs, HMI y deuda OT
- 3 Agua y energía
- 4 Aurora y Stuxnet

Andrés

- 1 Ucrania y The Grid
- 2 Shadow Brokers y NotPetya
- 3 Impacto social
- 4 Responsible Active Defense

Tesis: cuando el código puede afectar electricidad, agua o salud, la gestión de vulnerabilidades se convierte en responsabilidad pública.

Idea central

Nicole Perlroth presenta una industria opaca donde vulnerabilidades, brokers, contratistas y gobiernos convierten fallas técnicas en poder estratégico.

El proyecto aplica esa narrativa a infraestructura crítica: energía, agua, transporte, salud y sistemas industriales.

Base del libro

Author's Note: investigación construida durante años con entrevistas, fuentes sensibles y un mercado diseñado para evitar trazabilidad.

Prologue: Ucrania aparece como advertencia: ataques digitales contra instituciones, empresas, servicios civiles y red eléctrica.

La vulnerabilidad deja de ser un bug privado y pasa a ser un riesgo público.

2. Qué es un zero day

Roberto

Definición operativa

Un **zero day** es una vulnerabilidad desconocida públicamente o sin parche disponible.

Un **exploit** es la técnica o código que permite aprovecharla.

El **payload** es la acción posterior: espionaje, vigilancia, interrupción, sabotaje o persistencia.

Por qué importa

Mientras no exista parche, quien conoce la falla posee una ventaja temporal e invisible.

En infraestructura crítica, esa ventaja puede abrir rutas hacia sistemas que controlan procesos físicos.

Valor ofensivo = invisibilidad + tiempo antes del parche.

Libro: Chapter 1, *Closet of Secrets*.

Cadena del mercado



Dilema

Para el proveedor, la falla debe corregirse.
Para el broker, puede venderse.
Para el Estado, puede ser una capacidad.

Punto crítico

The Fucking Salmon condensa el dilema: el exploit se trata como producto, pero sus consecuencias pueden caer sobre infraestructura civil. El valor ofensivo depende de mantener la vulnerabilidad abierta.

La misma falla puede cerrar una puerta o convertirse en una capacidad militar.

Lectura ética

El mercado separa al vendedor de las víctimas potenciales. Esa distancia es el problema moral central.

Transformación

Un exploit deja de ser una prueba técnica cuando se usa para espionaje, sabotaje, vigilancia o coerción estatal.

La militarización ocurre cuando el código se integra a estrategias de poder nacional.

Riesgo estructural

La tecnología comercial es compartida por civiles, empresas, gobiernos y adversarios.

Una falla en software común no afecta solo al objetivo previsto.

La misma vulnerabilidad puede ser
herramienta de inteligencia o amenaza civil.

Libro: Part III, *The Spies*; Chapter 21, *The Shadow Brokers*.

IT

- Protege datos, identidad y aplicaciones.
- Prioriza confidencialidad e integridad.
- Tolera parches y reinicios con mayor frecuencia.
- El daño típico es digital o informacional.

OT

- Controla procesos físicos.
- Prioriza disponibilidad y safety.
- Usa equipos con ciclos de vida largos.
- El daño puede afectar operación real.

IT protege información. OT controla realidad física.

Referencias: NIST SP 800 82 Rev. 3; CISA Industrial Control Systems.

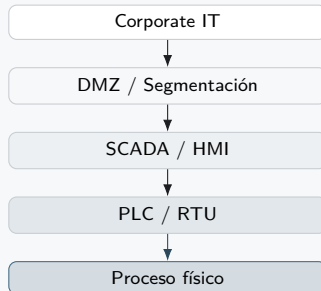
Tecnologías clave del libro

Siemens Step 7 y PLCs: puente entre malware y control físico.

GE Cimplicity y HMI: interfaz usada para visualizar y operar procesos industriales.

Water systems: plantas de agua comparten arquitectura OT con energía y transporte.

Ruta conceptual



El riesgo no depende solo del servicio, sino de la arquitectura común: sensores, HMIs, estaciones de ingeniería, PLCs, redes OT y procesos físicos.

Problema técnico

Muchos sistemas industriales fueron diseñados para entornos cerrados y confiables.

Protocolos como Modbus, DNP3 u OPC clásico priorizaron confiabilidad e interoperabilidad, no adversarios estatales conectados globalmente.

Security debt

La deuda de seguridad surge por:

- Equipos legacy.
- Parches diferidos.
- Acceso remoto de proveedores.
- Segmentación tardía.
- Inventarios incompletos.

El riesgo nace de conectar sistemas antiguos a un entorno moderno de amenazas.

Referencias: NIST SP 800 82 Rev. 3; CISA Best Practices; MITRE ATT&CK for ICS.

Operation Aurora

Ataque contra Google y otras empresas tecnológicas.

Lección: las empresas tecnológicas entran en la geopolítica de seguridad y cambian su postura corporativa frente a vulnerabilidades.

Stuxnet

Conecta malware, Siemens Step 7, PLCs y procesos físicos.

Lección: el objetivo no es solo entrar a una computadora, sino modificar lógica de control industrial.

Aurora Generator Test

Referencia externa: demostró que el código puede producir daño físico en infraestructura eléctrica.

Dos dimensiones del mismo problema: explotación invisible y daño físico posible.

Qué ocurrió

En diciembre de 2015, atacantes comprometieron sistemas relacionados con la red eléctrica ucraniana y apagaron circuitos.

El resultado fue pérdida de energía para cientos de miles de personas y presión directa sobre población civil.

Lectura del libro

Perlroth presenta Ucrania como laboratorio de ataques digitales rusos: elecciones, instituciones, empresas, servicios civiles y red eléctrica.

La red se convierte en mensaje político.

No fue robo de datos.
Fue coerción geopolítica mediante
infraestructura.

Libro: Prologue; Chapter 19, *The Grid*. Referencias: CISA Ukraine 2015; MITRE Campaign C0028.

Shadow Brokers

Herramientas ofensivas asociadas a capacidades estatales pueden filtrarse, reutilizarse o adaptarse.

El stockpiling depende de una premisa frágil: que el arsenal permanecerá bajo control.

NotPetya

Parecía ransomware, pero funcionó como malware destructivo.

Nació en el contexto de Ucrania, pero impactó logística, farmacéuticas, manufactura y operaciones globales.

Efecto boomerang: lo retenido como ventaja puede volver como daño sistémico.

Libro: Chapter 21, *The Shadow Brokers*; Chapter 22, *The Attacks*. Referencias: White House VEP; Greenberg, Wired NotPetya.

Ley y política

La infraestructura crítica pasa a ser prioridad de seguridad pública y gestión de riesgo institucional.

NIST, SEC y CIRCIA reflejan esa transición.

Percepción pública

Ciberseguridad deja de ser solo contraseñas y antivirus.

Ahora implica energía, salud, pagos, transporte y confianza.

Empresas

Se priorizan backups offline, segmentación, respuesta a incidentes, proveedores y resiliencia operacional.

El riesgo digital se desplaza de la pantalla a la vida cotidiana.

Referencias: NIST CSF 2.0; SEC Cyber Disclosure; CISA CIRCIA FAQs.

Qué sí es

- Gobernanza e inventario IT/OT.
- Segmentación y mínimo privilegio.
- Monitoreo OT y threat hunting.
- Respuesta coordinada.
- Backups offline y operación manual.
- Divulgación responsable.

Qué no debe ser

- Hack back privado.
- Represalias sin atribución confiable.
- Operaciones fuera de redes autorizadas.
- Escalamiento sin supervisión legal.
- Confundir defensa civil con defend forward estatal.

Defensa activa responsable = resiliencia sobre retaliación.

Referencias: NIST CSF 2.0; CISA Best Practices; White House VEP; DoD Cyber Strategy Summary.

Roberto

El mercado de zero days me hizo ver que una vulnerabilidad no es solo un logro técnico, sino una decisión moral.

Postura: divulgar responsablemente y reducir daño.

Pablo

En OT, proteger sistemas significa proteger procesos físicos, continuidad y seguridad humana.

Postura: prudencia, safety y comprensión operacional.

Andrés

Ucrania y NotPetya muestran que el daño digital no respeta fronteras limpias.

Postura: resiliencia antes que ofensiva.

Excelencia técnica no es solo poder romper sistemas, sino saber evitar que fallen sobre la sociedad.

Conclusión del informe

El libro muestra que los zero days se convirtieron en activos comerciales y militares.

Cuando esos activos se cruzan con infraestructura crítica, el riesgo deja de ser privado y pasa a ser público.

Si el software sostiene la vida moderna, protegerlo es una responsabilidad pública.

Mensaje final

- Divulgar responsablemente.
- Segmentar IT y OT.
- Preparar recuperación manual.
- Auditar decisiones ofensivas.
- Defender servicios esenciales.

Fuente	Uso en la presentación
Perlroth, N. (2021). <i>This Is How They Tell Me the World Ends</i> .	Base central del análisis: Author's Note, Prologue, zero days, Aurora, The Grid, Shadow Brokers, The Attacks y Epilogue.
White House. (2017). <i>Vulnerabilities Equities Policy and Process</i> .	Debate entre disclosure y stockpiling.
CISA. <i>Industrial Control Systems</i> .	Rol de ICS y OT en infraestructura crítica.
NIST. (2023). <i>SP 800 82 Rev. 3, Guide to OT Security</i> .	Diferencias IT/OT y seguridad de tecnología operacional.
CISA. <i>Cybersecurity Best Practices for ICS</i> .	Segmentación, reducción de exposición y controles defensivos.
MITRE ATT&CK for ICS.	Movimiento lateral y técnicas en entornos industriales.
Greenberg, A. <i>How 30 Lines of Code Blew Up a 27 Ton Generator</i> . Wired.	Aurora Generator Test y efecto físico del código.
CISA. <i>Cyber Attack Against Ukrainian Critical Infrastructure</i> .	Ataque contra red eléctrica ucraniana.
MITRE. <i>2015 Ukraine Electric Power Attack</i> .	Campaña técnica de Ucrania.
Greenberg, A. <i>The Untold Story of NotPetya</i> . Wired.	NotPetya y daño económico global.
NIST. (2024). <i>Cybersecurity Framework 2.0</i> .	Govern, Identify, Protect, Detect, Respond y Recover.
SEC. (2023). <i>Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure</i> .	Cambio regulatorio y gobierno corporativo.
CISA. <i>CIRCIQA FAQs</i> .	Reporte de incidentes en infraestructura crítica.
U.S. DoD. (2023). <i>Cyber Strategy Summary</i> .	Diferencia entre defensa civil y defend forward estatal.

Gracias

Preguntas